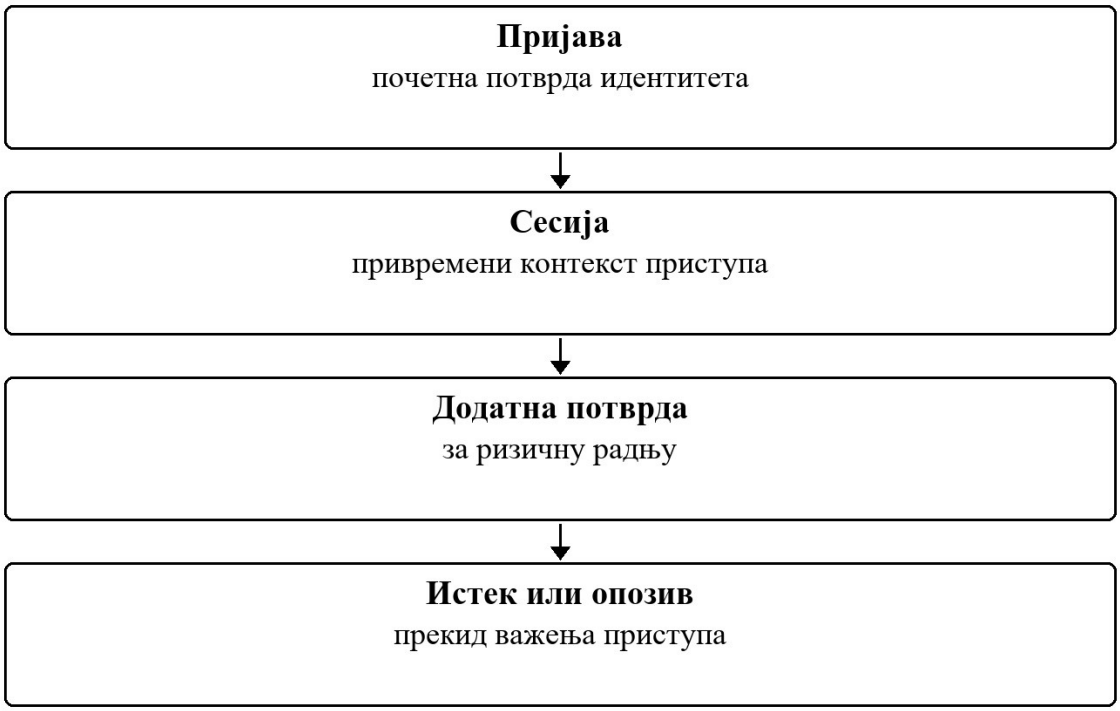
Вишефакторска аутентикација, сесије, сервиси и тајне

Основе информационе безбедности · 05

Идентитет није трајно доказан једном пријавом. Ризик радње, трајање сесије, врста уређаја и промена привилегија утичу на то колико је додатна потврда потребна. Оперативна безбедност зато прати приступ и након почетне аутентикације.

Вишефакторска потврда и временски ограничене привилегије смањују последице украденог креденцијала. Управљање тајнама штити везе међу сервисима, где непажња често остане скривена јер нема корисничког екрана.



Слика 1. Контрола приступа кроз време, а не само у тренутку пријаве

Безбедносна одлука настаје повезивањем приказаних појмова.

Циљ вежбе

Студент треба да образложи одлуку система, податке на којима се она заснива и њен утицај на заштиту података и услуга.

5.1 Приступ има рок и контекст

Вишефакторска потврда и временски ограничене привилегије смањују последице украденог креденцијала. Управљање тајнама штити везе међу сервисима, где непажња често остане скривена јер нема корисничког екрана.

- Сесија може изгубити важност пре планираног истека.
- Додатна потврда прати ризик радње, не само тип корисника.
- Сервисни идентитет има мали, јасно оправдан опсег, као и људски идентитет.

Питање за дискусију

Која радња заслужује додатну потврду идентитета и који догађај би требало да опозове постојећу сесију?

5.2 Како се ова тема види у развоју

Развојни тим унапред одређује које ситуације мењају ниво поверења: промена привилегије, приступ осетљивом податку или сумњива пријава. Тајне се референцирају из безбедног извора и никада се не преносе кроз код, тестне исписе или историју репозиторијума.

Честе грешке које треба препознати

- Токен третиран као вечна дозвола.
- Администраторска права додељена без рока и прегледа.
- Једна широка тајна дељена међу више независних сервиса.

Веза са осталим темама

Разматрана одлука повезује идентитет, податке, политике и доказе, а исти поступак анализе примењује се на различите врсте информационих система.

5.3 Пример: сесија после промене привилегије

Корисник се пријавио ујутру, а касније током дана добија виши ниво приступа. Ако систем не преиспита постојећу сесију, корисник може извршити ризичну радњу без додатне потврде која би била потребна да се пријављује у том тренутку. Обрнуто, одузета привилегија мора заиста да престане да важи, а не да чека крај дуготрајне сесије.

- Сесија представља привремени контекст приступа, а не трајну потврду поверења.
- Додатна аутентикација примењује се када ризик радње захтева виши ниво потврде идентитета.
- Сервисни налог има најмањи потребан опсег, рок важења и контролисану ротацију тајне.

Критеријуми решења

Решење треба да буде образложено пословним контекстом, примењено на серверској страни и потврђено поновљивим тестом, ревизијским записом или демонстрацијом.

5.4 Дизајнерска одлука: поверење се обнавља

Сесија олакшава рад кориснику, али њен комфор не сме постати трајно поверење. Систем мора знати када се околности мењају довољно да претходна потврда више није довољна. То могу бити промена привилегије, необичан уређај, ризична радња или сигнал да је налог угрожен.

- Истек ограничава трајање поверења чак и када нема видљивог инцидента.
- Опозив реагује на конкретну промену ризика и не чека да сесија природно нестане.
- Додатни фактор доказује присуство или поседовање независног средства, а не понавља само исту лозинку.

5.5 Тајне као део архитектуре

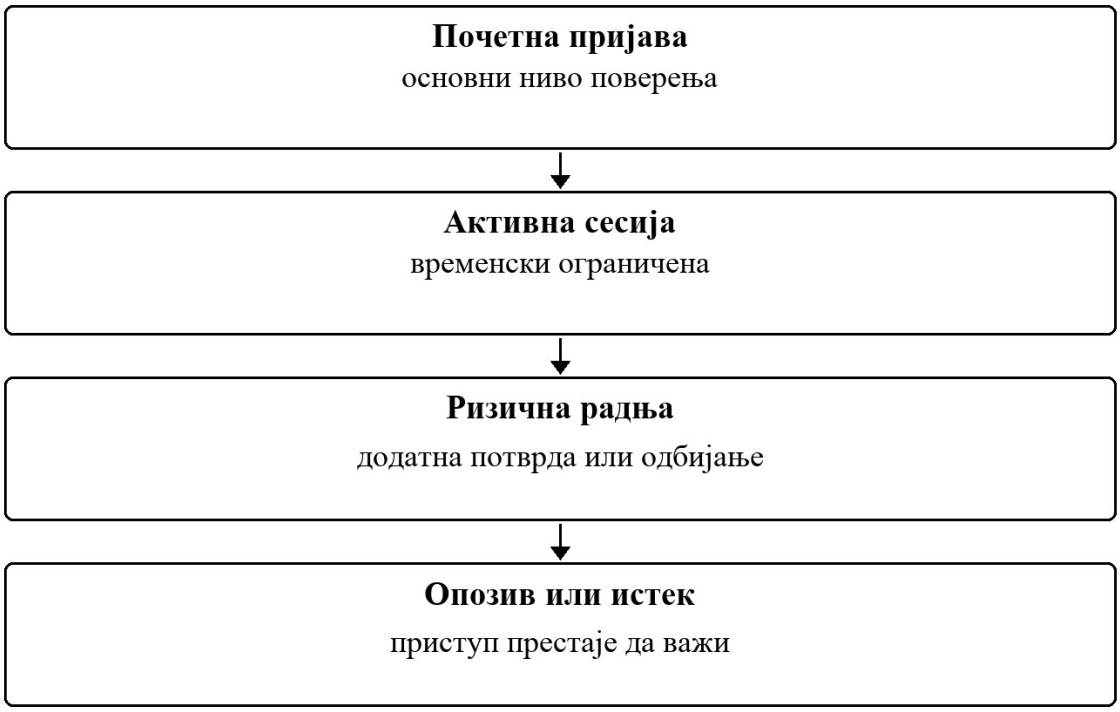
Тајна није конфигурациона вредност као свака друга. Њено излагање може дати приступ без видљивог корисничког екрана, нарочито између сервиса. Зато развојни процес дефинише одакле тајна долази, ко је користи, када се ротира и како се проверава да није случајно завршила у репозиторијуму или логу.

- Сваки сервисни идентитет има сврху и најмањи потребан опсег.
- Ротација се планира пре истека, уместо да се чека прекид рада.
- Тестови проверавају понашање при опозиву или истеку без приказивања стварних вредности тајне.

Самостална провера

За изабрани сценарио наведите одлуку система, коришћене податке, очекивани исход и доказ на основу ког други члан тима може да потврди резултат.

5.6 Шема животног циклуса поверења



Слика 2. Шема животног циклуса поверења

Поверење се не чува заувек. Систем га обнавља или опозива када се промени ризик.

За сваки корак шеме одредите покретача, одлуку која се доноси и запис који остаје након извршења.

5.7 Различите врсте идентитета

Табела 1. Идентитет и Намена

Идентитет	Намена	Посебан ризик
Људски корисник	Интерактивне радње и одговорност.	Крађа креденцијала или преширока улога.
Сервисни налог	Комуникација међу компонентама.	Тајна без рока или превелик опсег.
Привремени приступ	Кратка ризична интервенција.	Право остане активно након потребе.
Администраторски налог	Измене са великим утицајем.	Недостатак додатне потврде и аудита.

Тумачење поређења

Сваки појам описује посебан део безбедносне одлуке; тек њиховом правилном комбинацијом настаје целовит модел.

5.8 Од тајне до безбедне употребе

Безбедно управљање тајном почиње пре њеног првог коришћења. Потребно је знати власника, сврху, компоненту која је користи и начин ротације. Сама вредност тајне треба да остане ван кода, екрана и записа који нису за то намењени.

1. Тајна се издаје само идентитету који јој је стварно потребан.

2. Систем прати истек и планира ротацију пре прекида рада.

3. Логови бележе употребу и неуспех без приказивања вредности тајне.

4. Опозив ограничава последицу сумње да је тајна компромитована.

Исход учења

Студент треба да уме да изабере одговарајућа питања за анализу безбедносно значајне одлуке и да образложи редослед њихове примене.

Примена на пројекту

На додељеној пројектној целини применити принцип из теме „Вишефакторска аутентикација, сесије, сервиси и тајне". Идентификовати одлуку система, имплементирати је на серверској страни и припремити доказ у облику теста, ревизијског записа или демонстрације.

5.9 Извршиви пример

`StepUpAuthenticationPolicy` проверава да ли сесија има довољно свежу Вишефакторска аутентикација потврду за ризичну операцију. Одлука разликује одбијање и потребу за новом потврдом.

Пример 1. Покретање из репозиторијума наставног портала; потребан је дотнет 8 СДК.

```
cd examples/oib-dotnet/vezba-05-mfa-sesije-tajne
dotnet run --project src/Oib.Vezba05.ConsoleUi
dotnet test Oib.Vezba05.sln
```

Табела 2. Провера и Садржај

Провера	Садржај
Сценарио	Преузета, опозвана или давно потврђена сесија покушава поверљив извоз.
Тестови	`StepUpAuthenticationPolicyTests`, `AuthorizeRiskyOperationHandlerTests`
Доказ	`StepUpDecision` враћа код одлуке и ознаку да ли се тражи Вишефакторска аутентикација.

Задатак уз пример

Додати максималну старост саме сесије: сесија издата пре више од осам сати одбија се без обзира на Вишефакторска аутентикација. Увести нов код одлуке и тест за граничну вредност.